

Semana 26 - Aula 1

Tópico Principal da Aula: Segurança e manutenção de servidores Web

Subtítulo/Tema Específico: Atualizações e patches de segurança

Código da aula: [SIS]ANO2C2B4S26A1ANO2C2B4S26A1.pdf]

Objetivos da Aula:

- Implementar atualizações e patches para manter a segurança.
- Conhecer os riscos de manter sistemas desatualizados e as boas práticas de aplicação de patches em ambientes de produção.

Recursos Adicionais (Sugestão, pode ser adaptado):

- Caderno para anotações;
- Acesso ao laboratório de informática e/ou internet.

Exposição do Conteúdo:

Referência do Slide: Slide 04 - O que são Patches e Atualizações?

- **Definição:** Uma **atualização (update)** é uma versão mais completa de um software, que pode incluir novos recursos, melhorias de desempenho e correções de bugs. Um **patch (remendo)** é um pedaço de código que é inserido no software existente para corrigir especificamente uma ou mais falhas, geralmente de segurança (vulnerabilidades) ou de funcionamento.
- **Aprofundamento/Complemento:** Em um servidor Web, as aplicações (como Apache, Nginx, IIS), o sistema operacional (Linux ou Windows Server) e o software de banco de dados (MySQL, PostgreSQL) **devem** ser alvos de um processo rigoroso de patch. Ignorar essa rotina é a principal causa de exploração de sistemas, pois hackers utilizam ativamente listas públicas de vulnerabilidades conhecidas (CVEs) para atacar servidores desatualizados.
- **Exemplo Prático:** Uma vulnerabilidade crítica (Ex: **Log4Shell**) é descoberta em uma biblioteca Java (Log4j). A empresa responsável lança um *patch* de emergência. A equipe de TI deve aplicar esse patch imediatamente no servidor Web para evitar que um atacante execute código remoto no sistema.
 - Vídeo sugerido: [15 Dicas de VPS Seguro para Prevenir Ataques em Seu Servidor](#)
 - Vídeo sugerido: [Monitoramento de atualizações de software com o PRTG](#)

Referência do Slide: Slide 06 - Riscos da Desatualização e Boas Práticas

- **Definição:** O principal risco da desatualização é a **exposição a ataques cibernéticos** conhecidos e a **instabilidade operacional** do servidor. As boas práticas focam em mitigar esses riscos através de um processo estruturado.
- **Aprofundamento/Complemento:** Uma das boas práticas mais cruciais é o **Planejamento e Teste**. Nunca se deve aplicar um patch diretamente no ambiente de produção (servidor que os usuários acessam) sem antes testá-lo em um ambiente

de *staging* ou **desenvolvimento**, que simule o ambiente de produção. Isso evita que o patch, ao corrigir uma falha, cause uma quebra de funcionalidade crítica da aplicação.

- **Exemplo Prático:** Um analista deve estabelecer um cronograma mensal para patches (janela de manutenção). Antes de aplicar a atualização do kernel do Linux no servidor de produção, ele a aplica no servidor de testes e executa um conjunto de scripts automatizados para garantir que o servidor Web continue a responder e a executar as funções da aplicação corretamente.

Semana 26 - Aula 2

Tópico Principal da Aula: Segurança e manutenção de servidores Web

Subtítulo/Tema Específico: Backup e recuperação de dados

Código da aula: [SIS]ANO2C2B4S26A2ANO2C2B4S26A2.pdf]

Objetivos da Aula:

- Implementar estratégias de backup e recuperação.
- Diferenciar os tipos de backup e aplicar a regra 3-2-1 para garantir a resiliência dos dados.

Recursos Adicionais (Sugestão, pode ser adaptado):

- Caderno para anotações;
- Acesso ao laboratório de informática e/ou internet.

Exposição do Conteúdo:

Referência do Slide: Slide 04 - Tipos de Backup (Completo, Diferencial e Incremental)

- **Definição: Backup** é o processo de criar cópias dos dados para que possam ser restaurados em caso de perda. Os tipos principais são: **Completo (Full)** (copia todos os dados sempre), **Diferencial** (copia os dados alterados desde o último backup completo) e **Incremental** (copia os dados alterados desde o último backup completo ou incremental).
- **Aprofundamento/Complemento:** O tipo **Completo** é o mais lento de executar, mas o mais rápido de restaurar (requer apenas um arquivo). O **Incremental** é o mais rápido de executar, mas o mais lento de restaurar (requer o Full e todos os incrementais subsequentes). O **Diferencial** é um meio-termo, exigindo apenas o Full e o último Diferencial para restaurar. A escolha deve ser baseada na **RTO** (Recovery Time Objective) e **RPO** (Recovery Point Objective) do negócio.
- **Exemplo Prático:** Uma empresa faz um backup **Completo** todo domingo. De segunda a sexta, ela faz backups **Diferenciais**. Para restaurar os dados de quarta-feira, ela precisará apenas do backup de domingo (Completo) e do backup de quarta-feira (Diferencial).
 - Vídeo sugerido: [Tipos de Backup - @CursoemVideo - Módulo 03](#)

- Vídeo sugerido: [Tudo sobre Backup e Recuperação de Desastres: Garantindo a Segurança dos seus Dados!](#)

Referência do Slide: Slide 06 - A Regra 3-2-1 e Testes de Recuperação

- **Definição:** A regra **3-2-1** é um padrão fundamental de resiliência: manter **3** cópias dos dados, em **2** mídias diferentes, sendo **1** cópia fora do local (off-site ou na nuvem). **Recuperação de Desastres (DR)** é o plano para retomar as operações após uma interrupção catastrófica.
- **Aprofundamento/Complemento:** A cópia off-site protege contra falhas localizadas (incêndios, inundações ou ataques de *ransomware* que criptografam o armazenamento local). Mais importante do que fazer o backup é **testar a recuperação**. Um backup que não pode ser restaurado é inútil. Os testes devem ser realizados regularmente para verificar a integridade e o tempo de recuperação (RTO).
- **Exemplo Prático:** Uma empresa mantém 3 cópias do seu banco de dados: 1) Servidor de Produção (local), 2) HD Externo (mídia diferente, local) e 3) Cloud Storage (mídia diferente, off-site). Periodicamente, a equipe de TI simula uma falha de servidor e utiliza a cópia do HD Externo ou do Cloud Storage para restaurar o sistema, medindo o tempo gasto.

Semana 26 - Aula 3

Tópico Principal da Aula: Segurança e manutenção de servidores Web

Subtítulo/Tema Específico: Gestão de crises e incidentes

Código da aula: [SIS]ANO2C2B4S26A3ANO2C2B4S26A3.pdf]

Objetivos da Aula:

- Implementar gestão de crises e incidentes de segurança.
- Compreender o ciclo de resposta a incidentes de segurança e a importância da comunicação.

Recursos Adicionais (Sugestão, pode ser adaptado):

- Caderno para anotações;
- Acesso a um computador com internet.

Exposição do Conteúdo:

Referência do Slide: Slide 04 - Crise vs. Incidente de Segurança

- **Definição:** Um **Incidente de Segurança** é um evento específico que compromete a confidencialidade, integridade ou disponibilidade de um sistema (Ex: *malware*, *phishing*, invasão). Uma **Crise** é uma situação que ameaça a estabilidade ou

reputação da organização e exige uma resposta urgente da alta gerência, geralmente desencadeada por um incidente de segurança grave.

- **Aprofundamento/Complemento:** O foco da gestão de incidentes é técnico (conter a ameaça); o foco da gestão de crises é estratégico, legal e de comunicação (proteger a reputação e lidar com *stakeholders*). Ter um **Plano de Resposta a Incidentes (IRP)** bem definido é crucial para guiar as ações da equipe técnica e evitar que um incidente se transforme em uma crise generalizada.
- **Exemplo Prático:** Um ataque de *ransomware* criptografa apenas um servidor de testes (Incidente). Um ataque de *ransomware* criptografa o servidor principal de um e-commerce na Black Friday, vazando dados de clientes e parando as vendas (Crise). Neste último caso, a resposta envolve a equipe técnica, legal, de comunicação e o CEO.
 - Vídeo sugerido: [Como Criar um Plano de Resposta a Incidentes de Segurança Cibernética](#) (Link conceitual)
 - Vídeo sugerido: [O que é CSIRT e a Importância da Resposta a Incidentes](#) (Link conceitual)

Referência do Slide: Slide 06 - O Ciclo de Resposta a Incidentes

- **Definição:** O processo de resposta a incidentes segue um ciclo para garantir uma gestão eficaz: **1. Preparação** (treinamento e ferramentas), **2. Identificação** (detecção e análise), **3. Contenção** (isolar o sistema), **4. Erradicação** (remover a causa raiz), **5. Recuperação** (restaurar o sistema) e **6. Lições Aprendidas** (documentar e melhorar o IRP).
- **Aprofundamento/Complemento:** A fase de **Contenção** é a mais urgente; o objetivo é parar o dano rapidamente, mesmo que isso signifique desligar o servidor (o chamado "unplug" de emergência). A **Erradicação** exige uma investigação forense para garantir que o vetor de ataque (a vulnerabilidade inicial) seja realmente eliminado antes da recuperação.
- **Exemplo Prático:** Após detectar uma injeção de SQL (Identificação), o administrador imediatamente bloqueia o acesso externo ao banco de dados e isola o servidor Web (Contenção). Ele então analisa o código, corrige a falha na validação de entrada (Erradicação) e restaura o banco de dados de um ponto antes do incidente (Recuperação).